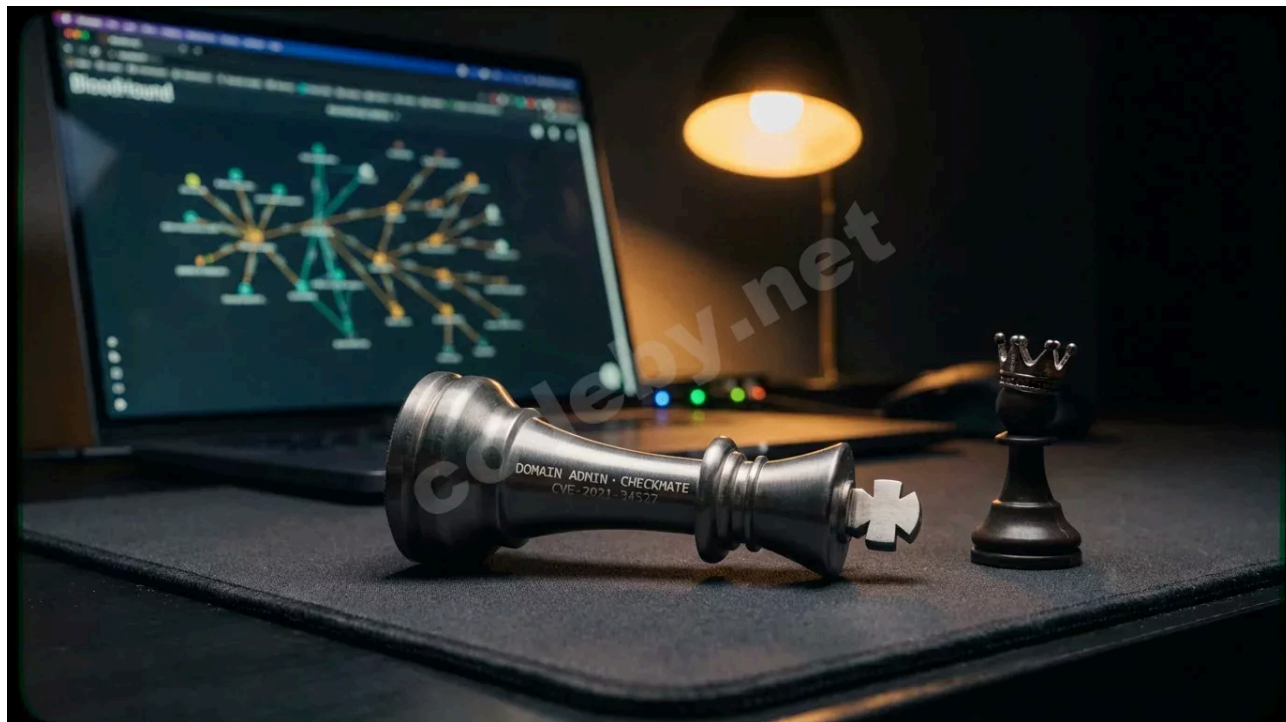


Статья Пентест Active Directory: полный гайд от разведки до Domain Admin — инструменты, техники, лабораторная среда

 codeby.net/threads/pentest-active-directory-polnyi-gaid-ot-razvedki-do-domain-admin-instrumenty-tekhniki-laboratornaya-sreda.92847

Cool9Ice

April 26, 2026



В большинстве внутренних пентестов, которые я провожу, путь от учётной записи рядового пользователя до Domain Admin занимает от 4 до 48 часов. Не потому что инфраструктура «дырявая» - а потому что Active Directory проектировалась для удобства администрирования, а не для противодействия атакующему с валидным доменным аккаунтом. Один забытый SPN на сервисной учётке с паролем Summer2024!, одна misconfigured ACL, выданная три года назад «на время миграции» - и граф BloodHound рисует прямую линию к KRBTGT. Эта статья - карта всех этапов такого пути: от первого LDAP-запроса до извлечения секретов контроллера домена.

Навигация по статье и кластеру

Ниже - обзор каждого этапа с ключевыми техниками, инструментами и практическими ориентирами. Каждая секция ссылается на детальный spoke-материал, где техника разобрана на уровне конкретных команд с флагами и артефактов в логах.

Разведка Active Directory: от первого пакета до полной карты домена

Разведка - этап, на котором формируется 80% успеха всего пентеста. Имея только доменную учётку уровня Domain Users, атакующий через стандартные LDAP-запросы получает доступ к колоссальному объёму информации: полный список пользователей и их атрибутов, все группы и вложенные членства, компьютеры с версиями ОС, объекты GPO, ACL на OU, доверительные отношения и FSMO-роли. Это не уязвимость - это штатное поведение протокола LDAP в Active Directory.

Однако стандартные LDAP-запросы легко детектируются современными SIEM и EDR - именно поэтому опытные атакующие прибегают к [обфускации LDAP-запросов Active Directory](#): изменению синтаксиса фильтров, разбивке атрибутов и манипуляциям с кодировкой, которые сохраняют функциональность запроса, но ломают сигнатурный детект. Там же разобрано, как SOC выстраивает обнаружение таких техник.

Что собираем и чем

Первые минуты после получения доступа к домену выглядят так:

- **Определение контроллеров домена** - DNS-запрос `_ldap._tcp.dc._msdcs.<domain>` отдаёт все DC, их IP и приоритеты. Альтернативно - `nslookup -type=SRV _kerberos._tcp.<domain>`.
- **Перечисление пользователей и SPN** - инструменты `ldapdomaindump` или `ldapsearch` выгружают пользователей с атрибутом `servicePrincipalName` (маркер для Kerberoasting), `userAccountControl` (флаг `DONT_REQ_PREAUTH` для AS-REP Roasting) и поле `description` (администраторы иногда записывают туда пароли).
- **Сканирование портов контроллера** - порты 53 (DNS), 88 (Kerberos), 135 (RPC), 389/636 (LDAP/LDAPS), 445 (SMB), 3268/3269 (GC) определяют доступные протоколы и attack surface. Nmap с `-sV` на этих портах покажет версии сервисов.
- **Анонимный SMB** - проверка `smbclient -L //<DC_IP> -N` покажет, доступны ли шары `SYSVOL`, `NETLOGON` или кастомные шары без аутентификации. В `SYSVOL` нередко лежат скрипты групповых политик с паролями в открытом виде.

Когда включать BloodHound

После базового перечисления следующий шаг - запуск SharpHound (коллектор данных для BloodHound). SharpHound собирает сессии, членства в группах, ACL, делегирование и trust-отношения через LDAP и Windows API, после чего BloodHound строит граф атакующих путей. На графе визуально видно: какой пользователь через какую цепочку прав может достичь Domain Admin.

Во множестве реальных engagement-ов именно этот граф становил главным аргументом в отчёте: оказывается, учётная запись мониторинговой службы состоит в

группе IT-Admins, у которой есть право GenericAll на OU с доменными администраторами - и эта цепочка строилась годами.

Подробный разбор инструментов разведки с конкретными командами и флагами - в нашем гайде: [Пентест Active Directory: полный гайд от разведки до Domain Admin в 2025](#). Построение графа атак и кастомные Cypher-запросы детально разобраны в материале [BloodHound Active Directory: разведка домена, построение графа атак и эксплуатация ACL](#).

Чеклист: минимальная разведка AD

- Получить список DC через DNS SRV
- Выгрузить всех пользователей с атрибутами через LDAP
- Определить учётки с SPN (для Kerberoasting)
- Определить учётки с DONT_REQ_PREAUTH (для AS-REP Roasting)
- Проверить анонимный доступ к SMB-шарам
- Запустить SharpHound и загрузить данные в BloodHound
- Проверить trust-отношения между доменами и лесами

Первоначальный доступ: LLMNR Poisoning, Responder и захват хешей NTLM

В сценарии grey box (самый частый формат пентеста AD) учётная запись уже есть. Но в black box или при Red Team-кампании первый доменный аккаунт нужно добыть. Классический вектор - отравление широковещательных протоколов разрешения имён.

Как работает атака

Когда Windows-машина не может разрешить имя через DNS, она отправляет широковещательный запрос по протоколам LLMNR (UDP 5355) и NBT-NS (UDP 137). Атакующий с Responder в том же сегменте сети отвечает раньше легитимного хоста, и жертва отправляет ему свой NTLMv2-хеш. Эта техника маппится на MITRE ATT&CK T1557.001 (LLMNR/NBT-NS Poisoning and SMB Relay).

Полученные хеши можно:

- **Брутфорсить офлайн** через Hashcat (-m 5600 для NTLMv2) - при слабом пароле результат за минуты.
- **Relay-ить** на другие хосты, где отключен SMB Signing, - через ntlmrelayx.py из Impacket. Если relay направить на LDAP контроллера домена, можно создать машинный аккаунт или провести атаку Shadow Credentials.

Согласно исследованию RedTeam Pentesting (2025), коэрсия (authentication coercion) через RPC-функции - логический следующий шаг после получения первого

доменного аккаунта. В отличие от LLMNR poisoning, coercion позволяет целенаправленно заставить конкретный хост аутентифицироваться на машину атакующего, что открывает путь к RBCD и S4U2Self abuse.

Что детектирует SOC

Responder генерирует характерный сетевой трафик: ответы на LLMNR/NBT-NS запросы с IP атакующего. Правила в SIEM на событие «новый responder в сегменте» - тривиальны, но на практике мониторинг этих протоколов отсутствует в большинстве инфраструктур.

Подробнее о защитных мерах, включая отключение LLMNR/NBT-NS через GPO и настройку LAPS для ротации локальных паролей, мы детально разобрали в материале [Харденинг Active Directory: LAPS, LLMNR и NBT-NS - три меры против 80% внутренних атак](#).

Если вы хотите понять, как защитные меры выглядят с позиции атакующего - как Protected Users Group блокирует Pass-the-Hash, почему Tiering Model ломает lateral movement и как LAPS меняет тактику при компрометации рабочей станции - читайте расширенный разбор: [харденинг Active Directory глазами атакующего](#).

Kerberoasting и AS-REP Roasting: атаки на домен Windows через Kerberos

Kerberos - основной протокол аутентификации в Active Directory, и именно его механика порождает два наиболее массово эксплуатируемых вектора: Kerberoasting и AS-REP Roasting.

Kerberoasting атака

Любой аутентифицированный пользователь домена может запросить у KDC сервисный тикет (TGS) для любого аккаунта с установленным servicePrincipalName. Тикет зашифрован хешем пароля этой сервисной учётки - его можно извлечь и брутфорсить офлайн. Ни один журнал не зафиксировывает сам факт офлайн-перебора; в логах DC появится только событие 4769 (запрос TGS) с типом шифрования 0x17 (RC4-HMAC), 0x11 (AES128) или 0x12 (AES256), что при массовых запросах от одного пользователя является индикатором Kerberoasting. RC4-запросы от современных клиентов - наиболее сильный сигнал, поскольку легитимные клиенты обычно используют AES; для AES-тикетов детект строится на аномальном количестве TGS_REQ к разным SPN от одного аккаунта.

Инструменты: GetUserSPNs.py из Impacket, модуль Invoke-Kerberoast из PowerView, Rubeus с параметром kerberoast.

AS-REP Roasting

Если у учётной записи отключена Kerberos pre-authentication (флаг DONT_REQ_PREAUTH в userAccountControl), атакующий может запросить AS-REP без знания пароля. Ответ KDC содержит часть, зашифрованную хешем пароля пользователя - её можно перебирать в Hashcat (-m 18200).

Практический takeaway

Параметр	Kerberoasting	AS-REP Roasting
Требуется домашняя учётка	Да	Нет (достаточно знать имя)
Целевые аккаунты	C SPN	C DONT_REQ_PREAUTH
Event ID на DC	4769 (enc type 0x17 = RC4, 0x11 = AES128, 0x12 = AES256; для AES детект по аномальному объёму TGS_REQ)	4768
Hashcat mode	-m 13100 (RC4), -m 19600 (AES128), -m 19700 (AES256)	-m 18200 (RC4), -m 19800 (AES128), -m 19900 (AES256)
Типичный результат	30-60% сервисных учёток ломаются за часы	Встречается реже, но пароли обычно слабее

Если вы в ситуации, где найдены десятки SPN-учёток - приоритезируйте те, которые входят в привилегированные группы (определяется через BloodHound). Нет смысла тратить GPU-время на учётку, которая ведёт в тупик.

Повышение привилегий Active Directory: ACL-атаки и делегирование Kerberos

После получения первых учётных данных начинается самый творческий этап - privilege escalation. Каждый домен уникален, и пути повышения привилегий зависят от конкретных ошибок конфигурации, накопленных за годы.

ACL-атаки: когда права выданы не тем

Active Directory хранит Access Control Lists на каждый объект: пользователя, группу, OU, GPO. Типичные опасные права:

- **GenericAll** - полный контроль над объектом. На пользователя = сброс пароля. На группу = добавление себя в неё. На компьютер = настройка RBCD.
- **GenericWrite** - запись произвольных атрибутов. Позволяет установить SPN (для Kerberoasting привилегированного аккаунта) или модифицировать msDS-KeyCredentialLink (Shadow Credentials).
- **WriteDACL** - право изменять сам ACL объекта. Атакующий может выдать себе GenericAll и далее эксплуатировать как выше.
- **ForceChangePassword** - сброс пароля без знания текущего.

BloodHound автоматически маркирует эти рёбра в графе. Но кастомные Cypher-запросы помогают найти неочевидные цепочки: например, пользователь А имеет WriteDACL на группу В, члены которой имеют GenericAll на OU с Domain Admins.

Делегирование Kerberos: три вида, три вектора

- **Unconstrained Delegation** - машина хранит TGT всех аутентифицирующихся пользователей. Если через козрцию (PetitPotam, PrinterBug) заставить DC аутентифицироваться на такую машину - его TGT попадёт в память, и атакующий получит DCSync-уровень доступа.
- **Constrained Delegation** - ограничена конкретным сервисом, но через S4U2Proxy + альтернативный сервис (alt-service) можно выйти за рамки.
- **Resource-Based Constrained Delegation (RBCD)** - атакующий, контролирующий машинный аккаунт, может настроить msDS-AllowedToActOnBehalfOfOtherIdentity на целевом хосте (если есть GenericWrite) и запросить тикет для имперсонации администратора.

Все эти техники, включая пошаговые цепочки с реальными примерами от GenericAll до DCSync, мы разобрали в отдельном материале: [Privilege Escalation в Active Directory: ACL-атаки, делегирование и цепочки от GenericAll до DCSync](#).

Pass-the-Hash и lateral movement: перемещение по сети без знания паролей

Получив NTLM-хеш доменного пользователя (например, из дампа LSASS через Mimikatz или из SAM через reg save), атакующий может аутентифицироваться на другие хосты без расшифровки пароля. Это Pass-the-Hash - одна из фундаментальных техник lateral movement в Active Directory.

Инструменты lateral movement

Инструмент	Протокол	Характерная особенность
psexec.py (Impacket)	SMB	Создаёт сервис на целевой машине, высокий уровень логирования (Event ID 7045)
wmiexec.py (Impacket)	WMI/DCOM	Не создаёт сервис, менее заметен для EDR
smbexec.py (Impacket)	SMB	Создаёт временный сервис на каждую команду (Event ID 7045), характерная command line с %COMSPEC% /Q /c и редиректом в named pipe
NetExec (наследник CrackMapExec)	SMB/WinRM/LDAP	Массовое выполнение команд, spray-проверка учётки
evil-winrm	WinRM (HTTP/5985)	Интерактивная сессия PowerShell, загрузка файлов

В 2025 году вместо устаревшего CrackMapExec рекомендуется использовать **NetExec** (nxc) - он активно поддерживается сообществом и расширяет функциональность: модули для LDAP-перечисления, проверки LAPS-паролей, автоматического Kerberoasting.

Что видит защитник

Pass-the-Hash оставляет характерный артефакт: событие 4624 с Logon Type 3 (Network) и типом аутентификации NTLM (не Kerberos). Массовые события 4624 от одного аккаунта на множестве хостов за короткий промежуток - прямой индикатор lateral movement. EDR-решения (CrowdStrike, Defender for Endpoint) также детектируют обращения к LSASS.

Подробнее об этих техниках с разбором каждого этапа и конкретными примерами - в нашем гайде: [Pass-the-Hash атака Active Directory: от NTLM-хеша до Domain Admin через lateral movement](#).

Атаки на контроллер домена: DCSync, Golden Ticket и Silver Ticket

Когда путь к привилегированному аккаунту пройден, следующий этап - извлечение секретов из базы данных Active Directory (NTDS.dit) и закрепление в домене.

DCSync атака

DCSync эмулирует поведение контроллера домена, запрашивающего репликацию данных через протокол MS-DRSR. Для этого аккаунт атакующего должен иметь права Replicating Directory Changes и Replicating Directory Changes All - они есть у Domain Admins, Enterprise Admins и самих DC по умолчанию. Команда `secretsdump.py -just-dc <domain>/<user>@<DC_IP>` из Impacket выгружает все хеши NTLM, включая хеш `krbtgt` - ключ к Golden Ticket.

На стороне SOC DCSync порождает событие 4662 с обращением к `1131f6aa-9c07-11d1-f79f-00c04fc2dcd2` (GUID для DS-Replication-Get-Changes). Это один из самых надёжных индикаторов.

Golden Ticket

Имея хеш `krbtgt`, атакующий может генерировать TGT для любого пользователя домена с произвольным временем жизни и произвольным группам привилегий. Golden Ticket переживает смену паролей всех пользователей - пока не будет дважды сброшен пароль `krbtgt` (в корректном порядке с интервалом, превышающим `MaxTicketAge`).

Silver Ticket

В отличие от Golden Ticket, Silver Ticket не обращается к KDC - он генерируется локально с использованием хеша машинного аккаунта целевого сервиса. Это делает его менее заметным, но ограничивает область применения конкретным сервисом (CIFS, HTTP, MSSQLSvc).

Подробный практический разбор всех трёх техник с примерами Impacket и Mimikatz - в материале: [Атаки на контроллер домена Active Directory: DCSync, Golden Ticket и Silver Ticket на практике](#).

AD CS атаки: эскалация привилегий через службы сертификатов

Active Directory Certificate Services (AD CS) - одна из самых недооценённых поверхностей атаки в корпоративных доменах. Если в инфраструктуре развёрнут Enterprise CA, атакующий может получить сертификат, позволяющий аутентифицироваться как Domain Admin, - и всё это без единого обращения к DC за Kerberos-тикетом.

Классификация ESC-уязвимостей

Исследователи SpecterOps систематизировали атаки на AD CS в виде классов ESC (Escalation Scenario). Наиболее критичные:

- **ESC1** - шаблон сертификата позволяет указать произвольный SAN (Subject Alternative Name). Атакующий запрашивает сертификат с SAN Administrator@domain.com и получает аутентификационный сертификат Domain Admin.
- **ESC8** - Web Enrollment endpoint AD CS доступен по HTTP без принудительного HTTPS. Позволяет relay NTLM-аутентификацию на CA и получить сертификат от имени жертвы.
- **ESC11** - аналогичен ESC8, но relay производится через RPC вместо HTTP.

Для обнаружения и эксплуатации используется **Certipy** - инструмент, который автоматически перечисляет шаблоны, определяет уязвимые конфигурации и выполняет запросы сертификатов.

Связь с коэрцией: согласно исследованию RedTeam Pentesting (2025), ESC8 и ESC11 - ключевые relay-цели при authentication coercion. Атакующий через PetitPotam (CVE-2021-36942, CVSS 7.5) принуждает DC аутентифицироваться, relay-ит сессию на CA и получает сертификат от имени DC. Далее - DCSync через PKINIT.

Полный практический гайд по каждому классу ESC с командами Certipy: [AD CS атаки эскалация привилегий: практический гайд по ESC1–ESC13 с Certipy.](#)

Coercion-техники 2025: PetitPotam, PrinterBug и обход новых митигаций

Authentication coercion - принуждение Windows-хоста аутентифицироваться на машину атакующего - остаётся одним из самых мощных векторов в пентесте Active Directory. По данным RedTeam Pentesting (блог от июня 2025), coercion с любым низкопривилегированным доменным аккаунтом обычно позволяет получить полный административный доступ практически к произвольным хостам и серверам Windows.

Как это работает

Атакующий вызывает RPC-функции на целевом хосте, которые заставляют его подключиться к атакующей машине с учётными данными машинного аккаунта. Далее этот аутентификационный поток relay-ится:

- На **LDAP** - для настройки RBCD или Shadow Credentials
- На (ESC8/ESC11) - для получения сертификата от имени целевой машины
- На **SMB** - если SMB Signing отключен на целевом хосте

Основные методы коэрции

Метод	RPC-интерфейс	Статус в 2025
-------	---------------	---------------

PetitPotam (CVE-2021-36942)	MS-EFSR (CVE-2021-36942 закрывает только EfsRpcOpenFileRaw; альтернативные методы - EfsRpcEncryptFileSrv и др. - остаются работоспособными после патча)	Патч Microsoft закрывает анонимный вызов, но аутентифицированный вызов работает
PrinterBug (SpoolService)	RpcRemoteFindFirstPrinterChangeNotification	Работает, если Print Spooler включён
DFSCoerce	NetrDfsRemoveStdRoot (DFSNM)	Работает на непропатченных системах
ShadowCoerce	Fs_RPC-вызовы (FileServerVSSAgent)	Ограниченно, зависит от конфигурации

Microsoft планомерно закрывает вектора: Enhanced Protection for Authentication (EPA) для LDAP-channel binding, обязательное требование подписи LDAP и новые митигации в Windows Server 2025. Однако, как отмечают исследователи RedTeam Pentesting, их патчи к Impacket и NetExec позволяют обходить ряд новых защит - что делает тему актуальной для каждого engagement-a.

Практический takeaway

Если вы на внутреннем пентесте и имеете доменную учётку:

Детальный разбор всех методов коэрции, включая NTLM Reflection и актуальные техники 2026 года с обходом новых митигаций Microsoft, собран в отдельном материале: [NTLM Coercion атаки Active Directory: от PetitPotam до NTLM Reflection в 2026.](#)

1. Проверьте, включён ли Print Spooler на DC (`rpcdump.py user:password@<DC> | grep MS-RPRN` или `nxc smb <DC> -u user -p pass -M spooler`)
2. Попробуйте PetitPotam с аутентификацией
3. При успешной коэрции - relay на AD CS (если есть) или на LDAP для RBCD

Критические CVE для пентеста Active Directory

Помимо техник, основанных на misconfiguration, существуют уязвимости, дающие прямой путь к эскалации. Вот наиболее значимые для AD-пентеста:

CVE	Название	CVSS	Суть
-----	----------	------	------

CVE-2020-1472	ZeroLogon	Microsoft/Secura: 10.0 Critical; NVD CVSS 3.1: 5.5 Medium (вектор AV:L - многими исследователями считается некорректным, т.к. атака идёт по сети через MS-NRPC)	Elevation of privilege через уязвимый канал Netlogon MS-NRPC. Позволяет неаутентифицированному атакующему получить доступ Domain Admin. Активно эксплуатируется (CISA KEV)
CVE-2021-34527	PrintNightmare	8.8 (High)	RCE через Windows Print Spooler. Произвольный код с привилегиями SYSTEM
CVE-2021-36942	PetitPotam	7.5 (High)	LSA Spoofing - принуждение аутентификации DC. Активно эксплуатируется (CISA KEV), в т.ч. в ransomware-кампаниях
CVE-2021-42278 + CVE-2021-42287	sAMAccountName Spoofing (noPac)	7.5 (High)	Цепочка: подмена sAMAccountName машинного аккаунта + получение TGT от имени DC
CVE-2022-26923	Certifried	8.8 (High)	Elevation of privilege через AD CS - подмена DNS-имени в сертификате (CWE-295)

Каждая из этих уязвимостей имеет рабочие PoC в публичном доступе. На реальных engagement-ах стоит проверять их в первую очередь - они дают быстрый путь к DC.

AD Pentest инструменты: арсенал Red Team оператора в 2025 году

Инструментарий для пентеста Active Directory стабилизировался вокруг нескольких ключевых проектов. Ниже - карта инструментов по этапам kill chain:

Разведка и перечисление

- **BloodHound CE + SharpHound** - построение графа атак. SharpHound собирает данные через LDAP и Windows API; BloodHound Community Edition (с Neo4j для графовой БД и PostgreSQL для метаданных приложения) визуализирует пути
- **Idapdomaindump** - выгрузка AD-объектов через LDAP в HTML/JSON. Быстрое перечисление без GUI
- **enum4linux-ng** - перечисление через SMB/RPC: пользователи, группы, шары, политика паролей
- **PingCastle** - сканер здоровья AD. Генерирует отчёт с оценкой рисков и визуализацией - отлично подходит для отчётов клиенту

Эксплуатация и lateral movement

- **Impacket** - набор Python-скриптов для взаимодействия с Windows-протоколами: secretsdump.py (DCSync, SAM dump), psexec.py / wmiexec.py (remote execution), GetUserSPNs.py (Kerberoasting), ntlmrelayx.py (relay)
- **NetExec (nxc)** - замена CrackMapExec. Массовое выполнение команд, проверка учёток, автоматизация spray-атак
- **Rubeus** - C#-инструмент для атак на Kerberos: AS-REP Roasting, Kerberoasting, S4U abuse, Pass-the-Ticket, Overpass-the-Hash
- **Certipy** - перечисление и эксплуатация AD CS (ESC1–ESC13)
- **Responder** - отравление LLMNR/NBT-NS и захват NTLMv2-хешей

Пост-эксплуатация

- **Mimikatz** - извлечение кредов из памяти (LSASS), генерация Golden/Silver Ticket, DCSync
- **Hashcat** - офлайн-перебор хешей (NTLMv2: -m 5600, NTLM: -m 1000, Kerberoast: -m 13100, AS-REP: -m 18200)

Пример минимального пайплайна для пентеста AD, от начала до проверки наличия пути к DA:

Bash:

```
# 1. Перечисление SPN-учёток (Kerberoasting)
GetUserSPNs.py -request -dc-ip 10.0.0.1 domain.local/user:Password1

# 2. Сбор данных для BloodHound (SharpHound из Linux)
bloodhound-python -c All -d domain.local -u user -p Password1 -ns 10.0.0.1

# 3. Массовая проверка: где текущий юзер - локальный админ
nxc smb 10.0.0.0/24 -u user -p Password1 --local-auth
```

Лабораторная среда для отработки атак на Active Directory

Без лабораторной среды осваивать атаки на AD - как учиться плавать по учебнику. Вот проверенные варианты:

GOAD (Game of Active Directory)

Проект Orange Cyberdefense, развёрнутый через Vagrant + Ansible. Содержит несколько доменов с trust-отношениями, предустановленные misconfiguration (Kerberoasting, RBCD, AD CS, LLMNR), уязвимые SPN-учётки и GPO. Идеален для отработки полного kill chain.

Требования: 16+ ГБ RAM, VirtualBox или VMware, ~60 ГБ дискового пространства.

Самописный стенд

Минимальный набор: Windows Server 2019/2022 (DC) + 1-2 Windows 10/11 (workstations) + Kali Linux. Стенд поднимается за час: Install-WindowsFeature AD-Domain-Services; Install-ADDSTForest (или через Server Manager), создание OU, пользователей с SPN, настройка намеренных misconfiguration (Unconstrained Delegation на одном хосте, слабый пароль на SPN-учётке, шаблон AD CS с ESC1).

Онлайн-площадки

HackTheBox Pro Labs (Dante, Offshore, RastaLabs) и TryHackMe AD-комнаты - готовые среды без необходимости разворачивать инфраструктуру локально.

Почему защита AD не работает без понимания атак: взгляд Red Team

Active Directory - технология с 25-летней историей, и её архитектурные решения (открытый LDAP для всех доменных пользователей, транзитивные trust-отношения, RC4 как fallback-шифрование) были нормой в 2000 году. Сегодня они - поверхность атаки.

Microsoft последовательно закрывает векторы: EPA для LDAP channel binding, AES-only Kerberos, Windows Server 2025 с обязательной подписью SMB. Но миграция занимает годы: в реальных средах я до сих пор встречаю Windows Server 2012 R2 контроллеры, SMB Signing Disabled и сервисные учётки с паролями, не менявшимися с 2016 года.

Тренд 2025 года - смещение фокуса атакующих на AD CS и coercion-техники. Если раньше основной путь к DA шёл через Kerberoasting + credential reuse, то сейчас цепочка «PetitPotam → relay на CA (ESC8) → сертификат DC → DCSync через PKINIT» работает быстрее и оставляет меньше артефактов в классических SIEM-правилах.

Что делать прямо сейчас:

1. Запустите PingCastle на своём домене - бесплатно, за 5 минут получите карту рисков.
2. Проверьте, отключены ли LLMNR и NBT-NS через GPO.
3. Ревизуйте SPN-учётки: сколько из них имеют пароли старше 1 года?
4. Проверьте AD CS: команда `certipy-ad find -u user@domain.local -p pass -dc-ip <DC> -vulnerable -stdout` покажет уязвимые шаблоны.

Если хотя бы один из этих пунктов выявит проблему - значит, полноценный пентест Active Directory вашей инфраструктуры необходим.

На Codeby вы можете заказать Red Team-проект или внутренний пентест с фокусом на Active Directory - наши инженеры проходят путь от учётной записи стажёра до Domain Admin и документируют каждый шаг с рекомендациями по устранению.

Вопрос к читателям

В последних engagement-ах я всё чаще вижу, что классический Kerberoasting через `GetUserSPNs.py -request` с RC4-тикетами блокируется на уровне AES-only политик Kerberos. При этом `Rubeus kerberoast /tgtdeleg` позволяет обойти ограничение, запросив AES-тикет через TGT delegation trick. Какой подход вы используете на engagement-ах, где DC настроен на `msDS-SupportedEncryptionTypes` только с AES128/AES256? Работает ли у вас связка `Rubeus kerberoast /enctype:aes256 /tgtdeleg /outfile:hashes.txt + Hashcat -m 19700` для AES-тикетов, и какова реальная скорость перебора на вашем железе по сравнению с RC4 (-m 13100)?

Последнее редактирование: